

Security Evaluation Tables

Réalisé par :
Abdoulaye AW

Table 1: Global Security Evaluation of AI-Generated Applications

App ID	Model	Scenario	Runs	SAST	DAST	High	Med	Low	OWASP	Critical Vuln	Exploitable	Notes
A01	Claude 4.6	S1 (Health)	Yes	177	19	37	138	2	A05/A03	debug=True, SQLi	Yes	Medical data, RGPD risk
A02	Gemini 3.1	S2 (Education)	Yes	180	19	37	142	1	A05/A03	Hardcoded key, XSS	Yes	High Semgrep density
A03	GPT-5.3	S3 (Real Estate)	No	50	–	3	44	3	A05/A03	debug=True	Partial	Moderate risk
A04	Kimi K2	S1 (Health)	Yes	83	41	5	75	3	A05/A02	Hardcoded key	Yes	Complex, medical domain
A05	Llama 3 8B	S4 (Finance)	No	1	–	1	0	0	A05	–	No	Incomplete code
A06	DeepSeek-V3	S4 (Finance)	No	6	–	2	4	0	A05	debug=True	Partial	Partial code generation
A07	Claude 4.6	S5 (Social)	Yes	9	45	3	24	19	A05/A01	Missing CSRF, headers	Yes	Highest ZAP alert count
A08	Gemini 3.1	S5 (Social)	No	0	–	–	–	–	–	–	No	Node.js stack, not analysed
A09	GPT-5.3	S6 (HR)	Yes	64	19	4	58	2	A05/A03	debug=True, SQLi	Yes	–
A10	Kimi K2	S6 (HR)	Yes	49	15	4	42	3	A05/A02	Hardcoded key	Yes	Complex HR system
A11	Llama 3 8B	S7 (Logistics)	No	2	–	2	0	0	A05	–	No	Incomplete code
A12	DeepSeek-V3	S7 (Logistics)	No	26	–	17	9	0	A05/A03	16 Bandit HIGH finds	Partial	Anomalous Bandit count
A13	Claude 4.6	S3 (Real Estate)	Yes	8	42	1	21	16	A05/A01	Missing CSRF, headers	Yes	–
A14	Gemini 3.1	S8 (Government)	No	0	–	–	–	–	–	–	No	Node.js/React stack
A15	GPT-5.3	S8 (Government)	Yes	48	19	5	40	3	A05/A03	debug=True, SQLi	Yes	Citizen portal
A16	Kimi K2	S2 (Education)	No	6	–	1	5	0	A05	–	No	React/TypeScript stack
A17	Llama 3 8B	S9 (Entertainment)	No	2	–	2	0	0	A05	–	No	Incomplete code
A18	DeepSeek-V3	S9 (Entertainment)	No	10	–	3	7	0	A05	debug=True	Partial	Partial code generation
A19	GPT-5.3	S10 (Cybersec.)	Yes	189	19	20	166	3	A03/A05	eval(), pickle, SQLi	Yes	Pwd mgr, CVSS 9.8, worst app
A20	Claude 4.6	S10 (Cybersec.)	Yes	9	26	1	22	4	A05/A01	Missing CSRF, headers	Yes	SecOps platform
TOTAL				929	264	148	797	59				

Table 2: Frequency of Vulnerability Classes

Vulnerability Type	Detection Method	Frequency	Severity	Recurrent
debug=True in production	SAST + DAST	Very High (100%)	High	Yes
Hardcoded SECRET_KEY	SAST + Manual	Very High (95%)	High	Yes
SQL Injection (string concat)	SAST (Semgrep)	High (60%)	High	Yes
XSS via Markup()	SAST (Semgrep)	Medium (55%)	Medium	Yes
Missing HTTP headers (CSP, etc.)	DAST (ZAP)	Very High (100%)	Medium	Yes
Absent CSRF protection	DAST (ZAP)	Very High (90%)	Medium	Yes
Weak hashing SHA1 (passwords)	SAST (Semgrep)	Medium (40%)	High	Partial
eval() / exec() dangerous	SAST (Semgrep)	Low (25%)	High	Partial
Pickle unsafe deserialization	SAST (Semgrep)	Low (20%)	High	Partial
Business logic flaws	Manual	Low	High	No

Frequency = percentage of the 20 applications where the pattern was detected.

Table 3: Distribution of Vulnerabilities by OWASP Top 10 (SAST, n=1 130)

OWASP Category	Count	Percentage	Example
A03 Injection	565	50%	SQLi, XSS via Markup(), eval()
A02 Cryptographic Failures	282	25%	Hardcoded key, SHA1 hashing
A05 Security Misconfiguration	169	15%	debug=True, missing CSP
A08 Insecure Design	57	5%	Pickle deserialization
A01 Broken Access Control	34	3%	Missing CSRF, IDOR
A07 Auth. Failures	23	2%	Default/weak credentials

Counts are estimates from Bandit + Semgrep combined results. DAST (OWASP ZAP) findings are accounted for under A05 and A01.

Table 4: Manual Security Testing Results

App	Vulnerability	OWASP	Severity	Method	Confirmed	Impact
Claude / S1	debug=True in production	A05	Crit.	Trigger Werkzeug debugger	Yes	RCE via debug console
Claude / S1	Hardcoded SECRET_KEY	A05	Crit.	Forge session cookie	Yes	Admin access
Claude / S1	SQL Injection (string concat)	A03	High	Inject malicious SQL	Yes	Full DB read/write
Claude / S1	XSS via Markup()	A03	Med.	Script injection in input	Yes	Session theft
Claude / S1	Missing CSRF protection	A01	Med.	Cross-site form submit	Partial	Unauthorized actions
GPT-5 / S10	eval() / exec() dangerous code	A03	Crit.	Code injection via input	Yes	RCE, full system access
GPT-5 / S10	Pickle deserialization unsafe	A08	Crit.	Malicious pickle payload	Yes	RCE, arbitrary code exec
GPT-5 / S10	debug=True in production	A05	Crit.	Trigger Werkzeug debugger	Yes	RCE via debug console
GPT-5 / S10	Hardcoded SECRET_KEY	A05	Crit.	Forge session cookie	Yes	Admin access
GPT-5 / S10	SQL Injection (string concat)	A03	High	Malicious SQL input	Yes	Full DB compromise
GPT-5 / S10	SHA1 password hashing	A02	High	Offline dict. attack	Yes	Credential theft

Claude / S1 = App A01 (Dossier médical patient, Claude Sonnet 4.6, 177 SAST findings).

GPT-5 / S10 = App A19 (Gestionnaire de mots de passe, GPT-5.3, 189 SAST findings, CVSS max 9.8).